



**UNIVERSIDAD TECNOLÓGICA DE
PANAMÁ
FACULTAD DE INGENIERÍA DE
SISTEMAS COMPUTACIONALES
LICENCIATURA EN DESARROLLO DE
SOFTWARE**



Nombre De La Asignatura:

Seguridad en los Sistemas de información

Tema:

Laboratorio 2- Amenazas y Vulnerabilidades.

Facilitador:

Prof. Lizmayrem Márquez

Presentado por:

Aburto, César	8-981-484
Becker, Manuel	8-16-1386
Jaén, Alexis	8-985-332
Jaén, Rubén	8-947-344
Pineda, Javett	9-747-2034
Tang, Keny	3-747-961
Torres, Aldhier	8-908-2405

Grupo:

1LS241

Fecha de Entrega:

Miércoles, 15 de abril de 2026

Índice

Contenido

1. El Incidente de la App (Mayo 2024).....	3
2. El Ciberataque Masivo (Julio 2025)	3
El Desenlace (Octubre 2025)	4
Identificar las tres vulnerabilidades.	4
1) Dependencia insegura de un tercero (Third-Party / Supply Chain Vulnerability)	4
2) Controles débiles frente a ingeniería social.....	5
3) Exceso de exposición de datos / principio de mínimo privilegio insuficiente	5
Identificar las tres amenazas.	6
1) Daño causado por un tercero	6
2) Acceso a la red o al sistema de información por personas no autorizadas....	6
3) Comprometer información confidencial (o se podría usar alternativamente Fuga de información).....	6
Cantidad de información sustraída en dólares o registros.	6
Mejoras que implementó la empresa para que este caso no vuelva a suceder.	7
Referencias bibliográficas	8

Resumen del incidente y causa del Incidente: ¿Por qué ocurrió?

1. El Incidente de la App (Mayo 2024)

Este no fue un hackeo, sino un **error de sistema**.

- **Qué pasó:** Los usuarios que abrían la aplicación de Qantas veían los datos de **otros clientes** en lugar de los suyos.
- **Detalles expuestos:** Nombres, puntos de viajero frecuente, próximos vuelos y, lo más grave, **pases de abordar activos**. Algunos usuarios incluso reportaron que podían cancelar los vuelos de desconocidos desde la app.
- **La causa:** Qantas explicó que se debió a cambios recientes en el sistema que causaron un error de "almacenamiento en caché" (caching issue), lo que hizo que la app entregara información cruzada.
- **Impacto:** Fue breve (unas horas), pero generó pánico sobre la seguridad de los datos financieros, aunque Qantas aseguró que los números de tarjetas de crédito no fueron visibles.

2. El Ciberataque Masivo (Julio 2025)

Este fue un ataque real y de gran escala.

- **El origen:** Los atacantes no entraron directamente a los servidores principales de Qantas, sino que explotaron una vulnerabilidad en una **plataforma externa** de atención al cliente gestionada por un proveedor (específicamente relacionada con **Salesforce**).
- **Responsables:** El ataque fue vinculado al grupo **Scattered Spider** (también conocidos como *Scatter Lapsus\$ Hunters*), famosos por usar ingeniería social para engañar a empleados de soporte técnico y obtener credenciales.
- **Magnitud:** Se comprometieron los datos de entre **5.7 y 6 millones de clientes**.
- **Técnica utilizada:** ingeniería social, eludir la autenticación multifactor y atacar sectores de alto valor.

¿Qué es una técnica de ingeniería social?

Es una técnica de manipulación psicológica, a la cual engaña a las personas y conseguir revelar información confidencial, descarguen software malicioso o realicen transferencias económicas. Esto lo que hacen es explotar el error humano y la confianza en lugares de vulnerabilidades técnicas.

- **Datos filtrados:**
 - Nombres y correos electrónicos.
 - Números de viajero frecuente y saldos de puntos.
 - Fechas de nacimiento y números de teléfono.
 - En algunos casos, direcciones físicas e incluso **preferencias de comida**.
- **Lo "bueno":** Qantas confirmó que **no se robaron** pasaportes ni números de tarjetas de crédito, ya que esa información no se guardaba en el sistema vulnerado.

El Desenlace (Octubre 2025)

A pesar de que Qantas contuvo el ataque en julio, en octubre de 2025 se confirmó que los datos robados fueron publicados en internet por los ciberdelincuentes tras no recibir un pago de rescate.

Identificar las tres vulnerabilidades.

1) *Dependencia insegura de un tercero (Third-Party / Supply Chain Vulnerability)*

¿Qué vulnerabilidad fue?

Qantas utilizaba una **plataforma externa de atención al cliente** que tenía acceso a información sensible de pasajeros. Esa dependencia abrió una puerta de entrada.

¿Por qué es vulnerabilidad?

Porque la empresa **no solo debe proteger sus propios sistemas**, sino también cualquier **proveedor, SaaS o plataforma externa** conectada a su operación. Si el tercero tiene controles más débiles, se convierte en el **eslabón más frágil**.

En palabras simples:

El atacante no tuvo que romper la puerta principal de Qantas; le bastó con entrar por una puerta lateral del proveedor.

Vulnerabilidad 1: Exposición de datos sensibles en una plataforma de terceros utilizada por el centro de contacto, lo que amplió la superficie de ataque y permitió acceso no autorizado a información de clientes.

2) Controles débiles frente a ingeniería social

¿Qué vulnerabilidad fue?

El incidente fue asociado públicamente con tácticas de **ingeniería social** contra operaciones de soporte / contact center.

¿Por qué es vulnerabilidad?

Porque si el personal o los procesos de soporte:

- confían demasiado rápido,
- no verifican identidad de forma robusta,
- o pueden conceder acceso con validaciones insuficientes,

entonces el atacante puede entrar **sin necesidad de explotar un software técnicamente complejo**.

En palabras simples:

Si una persona puede ser engañada, el sistema completo también puede caer.

Vulnerabilidad 2: Falta de controles humanos y procedimentales suficientemente resistentes frente a ataques de ingeniería social dirigidos al personal del centro de contacto.

3) Exceso de exposición de datos / principio de mínimo privilegio insuficiente

¿Qué vulnerabilidad fue?

La plataforma comprometida almacenaba **grandes volúmenes de datos personales de millones de clientes**.

¿Por qué es vulnerabilidad?

Porque aunque el sistema fuera “solo” de atención al cliente, contenía una **cantidad demasiado valiosa de información**. Esto sugiere una debilidad de seguridad del tipo:

- **demasiados datos accesibles en un mismo lugar,**
- segmentación insuficiente,
- o aplicación débil del principio de “**mínimo privilegio**” y **minimización de datos**.

En palabras simples:

Aunque el sistema no guardara tarjetas, sí guardaba suficiente información personal como para volverlo un objetivo muy atractivo.

Vulnerabilidad 3: Concentración y exposición de grandes volúmenes de datos personales en una plataforma operativa de atención, sin una segmentación o minimización suficientemente fuerte para reducir el impacto de una intrusión.

Identificar las tres amenazas.

1) *Daño causado por un tercero*

Aplicación al caso: Esta amenaza cubre el hecho de que el ataque no entró directamente por la infraestructura principal de Qantas, sino a través de su proveedor externo (el call center en Filipinas). La vulneración de este tercero fue la puerta de entrada que causó el daño a la aerolínea.

2) *Acceso a la red o al sistema de información por personas no autorizadas*

Aplicación al caso: Los cibercriminales, tras engañar al operador telefónico, lograron evadir los protocolos de autenticación y entrar ilegalmente a la plataforma de atención al cliente conectada a las bases de datos de la empresa.

3) *Comprometer información confidencial (o se podría usar alternativamente Fuga de información)*

Aplicación al caso: Esta amenaza se materializó cuando los atacantes lograron extraer los datos personales y de viajero frecuente de casi 6 millones de clientes, culminando con la exposición y publicación de todos esos registros en la dark web.

Cantidad de información sustraída en dólares o registros.

Afectados: 6,000,000 de clientes (casi 1 de cada 4 australianos).

Tamaño del robo: 153 GB de archivos de texto y listas.

El rescate: Qantas pagó \$0. Prefirieron que la información se filtrara antes que darle dinero a los criminales.

Precio de los datos: En el mercado negro, los hackers intentaron vender tu información por solo \$27 dólares. Como nadie la compró, la terminaron regalando en internet para dañar la reputación de la aerolínea.

Mejoras que implementó la empresa para que este caso no vuelva a suceder.

Mejoras implementadas por Qantas (Post-incidente 2025)

Tras la contención del ataque en julio de 2025 y la posterior filtración en octubre del mismo año, Qantas reforzó su postura de seguridad centrándose en el eslabón más débil: sus proveedores externos y el factor humano. Las mejoras clave incluyen:

- **Reforzamiento del Monitoreo y Detección:** La aerolínea implementó sistemas de monitoreo continuo y detección de anomalías en tiempo real para todas las plataformas conectadas a sus bases de datos, no solo en sus servidores internos, sino también en los de terceros.
- **Endurecimiento de Accesos de Terceros:** Se establecieron controles de acceso más estrictos para proveedores (como el call center en Filipinas), exigiendo el uso de **autenticación multifactor (MFA) resistente al phishing** (basada en hardware o criptografía) para evitar que los ataques de ingeniería social de grupos como Scattered Spider tengan éxito.
- **Capacitación Especializada en Ingeniería Social:** Se incrementaron los programas de entrenamiento para empleados y contratistas, enfocándose específicamente en detectar tácticas de **vishing** (phishing de voz) y suplantación de identidad, que fue el método principal de entrada en este caso.
- **Acciones Legales y Protección de Datos:** La empresa obtuvo una orden judicial (injunction) ante la Corte Suprema de Nueva Gales del Sur para prohibir legalmente el uso, publicación o distribución de los datos robados, mientras trabaja con expertos en ciberseguridad para rastrear la información en la dark web.

<https://www.qantas.com/en-au/help/cyber-safety-scams/cyber-incident>

- **Gobernanza de Identidades No Humanas:** Qantas comenzó a tratar las llaves de API y conectores de software (como los de Salesforce) como identidades críticas, implementando credenciales de corta duración y permisos de "mínimo privilegio".

<https://nhimg.org/community/non-human-identity-management-general-discussions/lessons-learned-from-the-qantas-2025-data-breach/>

Referencias bibliográficas

https://www-cm--alliance-com.translate.goog/cybersecurity-blog/qantas-data-breach-scattered-spider-takes-to-the-skies?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc

https://www-computerweekly-com.translate.goog/news/366626941/Scattered-Spider-link-to-Qantas-hack-is-likely-say-experts?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc
<https://www.qantas.com/en-au/help/cyber-safety-scams/cyber-incident>

<https://www.qantas.com/agencyconnect/gb/en/agency-news/agency-news-july-25/qantas-cyber-incident.html?>

<https://www.qantas.com/pg/en/support/information-for-customers-on-cyber-incident.html?>

<https://australiawatch.net/politics/qantas-cyber-incident-2025/?>

Hay videos también sobre este incidente:

https://www.youtube.com/results?search_query=scattered+spider+ataca+a+qantas